10 Questions to Ask Your IT Provider About Cybersecurity

A capable IT provider should be able to answer every one of these clearly and specifically. Vague answers are data.

> How to Use This Resource: Take these questions into your next review conversation with your IT provider. You are not looking for jargon. You are looking for specific, measurable answers. Where you get generalities, ask for the specific metric, report, or process behind the claim.

1. Who is monitoring our environment at 2am on a Saturday?

What you are listening for: a named tool, a named team, and a defined escalation process. "We have antivirus and alerting" is not 24/7 monitoring. If the answer is that alerts go to a ticketing queue and get reviewed during business hours, your environment is unmonitored outside of business hours.

> Follow-up: What was the last alert generated in our environment, and when was it reviewed?

2. What are your mean time to detect and mean time to respond benchmar

Mean time to detect (MTTD) is how long it takes to identify that a threat is present. Mean time to respond (MTTR) is how long it takes to contain it. These are measurable numbers. Industry average MTTD without a dedicated security function is around 200 days.

> Follow-up: Can you show us these metrics for our environment specifically over the last quarter?

3. Have you assessed our environment against ASD Essentials?

ASD Essentials replaced the Essential Eight in October 2026. A proper assessment tests whether controls are actually enforced and effective, not just configured. If they have done one, ask for the report. If they only have an old Essential Eight assessment, ask when they will map it to ASD Essentials. If they have neither, ask when it will be scheduled.

> Follow-up: Which domains have you assessed, and which actions are rated not effective or partially effective?

4. How are we patching and how quickly?

The ASD recommends patching internet-facing applications within 48 hours of a critical vulnerability being published. Operating systems within 48 hours for extreme risk, two weeks for everything else. Monthly patching cycles leave known vulnerabilities open for up to 30 days.

> Follow-up: Can you show us our current patch compliance report and the average age of unpatched critical vulnerabilities?

5. Is MFA enforced across all accounts, and are legacy authentication prot

MFA being available is not the same as MFA being enforced. Legacy authentication protocols bypass MFA entirely. If basic authentication, IMAP, or POP3 are still permitted in your Microsoft 365 environment, MFA is protecting less than you think.

> Follow-up: Show us the conditional access policy that blocks legacy authentication and confirm there are no exceptions.

6. How are administrative privileges managed?

How many accounts have domain admin or local admin rights? How is that list reviewed? Are IT staff working day-to-day from admin accounts?

> Follow-up: Can you pull the current list of accounts with admin privileges and walk us through the last time it was reviewed?

7. Walk us through what happens when a threat is detected.

You want a specific process: who gets the alert, who investigates, what the containment steps are, how quickly isolation happens, and how you as the business are notified. A provider with a real process will answer this without hesitation.

> Follow-up: Has this process been tested in a tabletop exercise or simulation in the last 12 months?

8. Are our backups tested and is at least one copy stored offline or immuta

Backups that have never been tested may not restore. Backups stored on the same network as the systems they protect can be encrypted by ransomware along with everything else.

> Follow-up: When was the last time a full restore was tested from our backups, and what was the result?

9. What have you proactively recommended in the last six months that we

A security-aware IT provider brings things to your attention before you think to ask. New threat patterns relevant to your industry. Configuration gaps found during routine work. Emerging risks.

> Follow-up: If the answer is limited, ask what threat intelligence sources they are monitoring and how that informs their recommendations.

10. What is outside your scope?

This is the most important question. Most IT providers have genuine limits to their security capability and the honest ones will tell you where those limits are. Knowing what your current provider does not cover tells you where the gaps are, which is information you need to manage your risk properly.

> Follow-up: Who would you recommend engaging for the areas outside your scope, and are you willing to work alongside a specialist security partner?

What to Do With the Answers

A provider who answers all ten questions clearly, specifically, and with evidence is a provider who is genuinely on top of your security. That is worth knowing.

A provider who cannot answer several of these questions, or who gives vague responses without specifics, is a provider whose security capability may not match what you are paying for or what you need. That is also worth knowing.

This is not about catching anyone out. It is about understanding what you actually have in place so you can make informed decisions about your risk.

Want an independent view?

Stealth Cyber provides independent cybersecurity assessments and managed protection for Australian professional services firms. If you want a straight read on your current security posture, get in touch.

WEBSITE
stealthcyber.io

EMAIL
contact@stealthcyber.io

PHONE (AU)
+61 7 5230 8381

PHONE (US)
+1 (855) 774-2595

OFFICES
Gold Coast, AU | Sao Paulo, BR | Texas, US

© 2026 Stealth Cyber Pty Ltd. ABN 72 675 840 632. All rights reserved.